Security, privacy and governance

How the agent protects personal data, where the guardrails sit, and how it fits the EU AI Act and GDPR. The full governance document with the processing table is governance.pdf.

> This is a course project with fictional people. It is not legal advice. A real deployment needs a review by the data protection officer.

1. Guardrails around the AI

Code checks sit on both sides of every AI step.

Input: before the AI (workflow 3, node `Input guard`)

Check	What happens
IBAN, tax ID, social security number typed into the chat	Removed before anything is stored or sent. Stored as `[removed: personal data]`
Request about another person's data	Refused, no AI call
Prompt injection, English and German	Blocked with a fixed reply
Greeting, thanks, off-topic, empty, over 1,500 characters	Fixed reply, no AI call
E-mail addresses, phone numbers, codes	Masked in the chat log
Too many messages	Rate limit per session, circuit breaker after AI failures

Output: after the AI (workflow 3, node `Answer check`)

Check	On failure
The answer cites a source file	Hand-off to People Ops
The cited file was really retrieved	Hand-off
Every number in the answer appears in that source	Hand-off
No ID numbers, no internal rules leaked	Hand-off
At most 250 words	Hand-off

The user then sees "People Ops will answer you", and the question is posted to `#hr-helpdesk`. **The assistant never guesses.**

In the onboarding flow

- The AI welcome draft is checked in code (workflow 1, `Check welcome draft`): no money, salary or contract terms, otherwise a safe template.
- ID numbers are removed from HR notes.
- HR approves every message before it leaves the company.
- The AI never decides whether a hire is valid. Rules in code do.

2. Bank, tax and social security data

These are the most sensitive data in onboarding. The AI, the chat log, Discord, LangSmith and n8n's execution history never see them.

Layer	Protection
Collection	Only in the secure form (workflow 11). Never by e-mail or chat
Link	Single use, valid 14 days, stored only as a hash (`pfb_requests.token_hash`)
Identity	Personal code from the welcome e-mail, lockout after 5 wrong tries
Validation	IBAN mod 97, tax ID and social security number checksums before saving
Storage	`pgp_sym_encrypt` (OpenPGP, AES-256) with the key `pfb_encryption_key` in Supabase Vault. The bytes start with `c30d04`
HR view	Only "received" and a masked IBAN, for example `DE02 •••• 2051`
Payroll view	Separate login, one record at a time, every view and export logged in `payroll_access_log` (who, when, never the values)
n8n	Workflows 11 and 12 save no execution data

3. Access control

Area	How it is protected
Website (5)	Public company page without login and without the assistant. Employee area `/webhook/brewtec/employees` with a personal login per employee: work e-mail and password, bcrypt hash in `website_users`, 5 wrong passwords lock the account for 15 minutes, disabled accounts refused, every attempt in `website_login_log` (kept 1 year, never the password)
HR portal (10)	HR Basic Auth login and HMAC-signed (Hash-based Message Authentication Code) page tokens on every form post
Payroll portal (12)	Separate payroll Basic Auth login and signed page tokens
Mock Workday API (9)	Bearer token, 401 without it
Assistant: own tasks	Personal code, attempts logged in `code_attempts`, lockout and expiry
Database functions	`execute` revoked from `anon` and `authenticated`, only the service role can call them
Grafana business view	Read-only role `grafana_reader` that sees only the seven `reporting` views, never `employees`, `chat_messages` or `payroll_details`

Why the chat endpoint has no login: workflows 7 and 13 call it directly for the quality check and the automated tests. Its address is a long random id, it has rate limits per session, and personal answers need the personal code. With company single sign-on in front of the whole site (roadmap) it would be covered too.

Known limit of browser logins: the browser remembers the login until it is closed, there is no logout button. Company single sign-on fixes this.

Why signed page tokens: n8n serves webhook pages in a sandbox, so the browser sends `Origin: null` and an origin check blocks real users. A token signed with HMAC SHA-256 (`portal_token`, `portal_token_check`) proves the form came from the portal page, and it expires.

4. Data retention and rights

`purge_expired_data` runs every day from workflow 4:

Data	Kept for
Chat messages	90 days
Code attempts, cached answers	30 days
Automation logs	1 year
Hires sent back by HR	180 days

`erase_employee(employee_id)` deletes one person's onboarding data on request (right to erasure). Automatic deletion of payroll details after the legal retention period is on the roadmap.

Where chat text exists

Place	What is kept	How long
Supabase `chat_messages`	Cleaned question, reply, source or hand-off reason	90 days
Supabase `answer_cache`	General verified answers only, never personal or health questions	Reused 7 days, deleted after 30 days
n8n chat memory	Last 8 exchanges of one chat	Until n8n restarts
n8n executions of workflow 3	The question as received, after the input guard removed ID numbers	Until n8n prunes executions (default 14 days)
LangSmith traces	The question sent to the model, without ID numbers, and the answer	LangSmith retention of the account
Discord `#hr-helpdesk`	Hand-offs: the cleaned question and the reason	Until deleted in Discord

Open items for production: switch off saving successful executions for workflow 3 (as already done for workflows 11 and 12), and set LangSmith to hide inputs and outputs of the assistant, so a health question typed in the chat is not kept outside the cleaned chat log.

5. EU AI Act

AI used in employment (recruitment, task allocation, monitoring of workers) is listed as **high risk** in Annex III. The agent works in that area, so it is treated as high risk, and BrewTec is the **deployer**. The design keeps people in charge:

- The AI only **drafts text** and **answers questions from cited documents**.
- Every decision about a person is made by **rules in code** or **by HR**.
- HR approves every outbound message (human oversight).
- Employees are told that the assistant is an AI, and every answer names its source (transparency).
- Every AI call is traced in LangSmith (logging).

Open before go-live, because they need people outside the project: a bias review of the welcome drafts, a data protection impact assessment (DPIA) and a works council agreement (Betriebsvereinbarung).

6. Responsible AI checklist

Item	Status
Human approval before anything is sent to a new hire	Done
AI answers only from official documents, with the source	Done
Hand-off instead of guessing	Done
No sensitive data reaches the AI	Done

Item	Status
Every AI call traced (LangSmith)	Done
Weekly quality score with human review of 5 real answers	Done
Automated tests after every prompt change	Done (workflow 13)
Bias check of the rules and work e-mail across name origins	Done, one problem found and fixed (see Responsible AI)
Bias review of AI welcome drafts across names	Open
Data protection impact assessment	Open
Works council agreement	Open
Chat text kept only in the cleaned chat log (n8n executions and LangSmith inputs off)	Roadmap
Company single sign-on instead of Basic Auth	Roadmap
Hosting in Germany with HTTPS	Roadmap

7. Secrets in this repository

There are none. Workflow JSON files contain credential names, not credential values. `.gitignore` excludes `.env` files, credential exports and n8n data. Screenshots that showed webhook URLs, tokens or real e-mail addresses were removed or redacted.